

What Is Offensive Security?

Unit 01 — Ethics, Law & the Hacker Mindset

Before we touch a single tool, we learn the one rule everything else depends on:
authorization is the only line between a penetration tester and a criminal.

Learning objectives

By the end of this unit you can:

- **Define** offensive security and why companies attack themselves.
- **Distinguish** white-, gray-, and black-hat hackers.
- **Tell apart** red, blue, and purple teams.
- **Explain** what the CFAA prohibits — minors included.

Learning objectives (cont.)

- **Identify** authorization and scope as the dividing line.
- **Explain** responsible disclosure and bug bounties.
- **Classify** scenarios as legal/illegal and ethical/unethical.
- **Apply** the "Try Harder" mindset and set up your journal.



The one rule

**Authorization is the only line
between a penetration tester
and a criminal.**

Everything offensive in this course happens **only** in isolated, pre-approved labs — and **only** after the AUP is signed.

How this unit works

- This week is **discussion and case study only**.
- **No tools, no hacking, no scanning** — nothing to attack.
- We build **judgment first**, skills later.
- The point: good decisions matter more than clever tricks.

You earn the tools by first proving you can be trusted with them.

Day 1 — What is offensive security, and why does it exist?

Warm-up

On the board:

*"Why would a company **pay** someone to break into its own systems?"*

Write a one-sentence guess. We'll share a few.

Offensive security, defined

- **Offensive security** = attacking systems *on purpose, with permission*.
- The goal: find weaknesses **before criminals do**.
- It is planned, legal, and ends in a written report.

Same actions as an attack — but invited, and aimed at fixing things.

Pentest and pentester

- A **penetration test** is an authorized, simulated attack.
- A **penetration tester** is hired and given **written permission**.
- They attack, then **report** what they found.

The deliverable is a report that makes the defenders stronger — not damage.

The core idea

You can't protect what you don't understand.

- Defenders need to know how attackers actually think.
- Find the weak door first, then lock it before a criminal walks through.
- **Offense feeds defense.** That's the whole point of this field.

Real-life analogies

Real world	Security equivalent
Locksmith picks your lock to prove it's weak	A tester finds a weak login
Crash-testing a car before it ships	Testing an app before attackers do
A fire drill	A simulated attack / red-team exercise

Good-guy testers find the weakness **so it can be fixed** — with permission.

Worked example: the bank vault

- A bank hires a team to **try to break into the vault**.
- They find a side door left unlocked at night.
- They **report it** — they don't take anything.

The bank fixes the door. That's offensive security in one story.

Check your understanding

Which is the **best** description of offensive security?

- A) Breaking into systems for fun
- B) Legally attacking systems **with permission** to find weaknesses first
- C) Writing antivirus software
- D) Reporting people who hack

Answer

B — Legally attacking systems with permission to find weaknesses before criminals do.

- It's planned, **authorized**, and aimed at fixing things.
- The other options miss the permission and the goal.

Fun, antivirus, and reporting people are not the definition.

Day 1 work: start your lab journal

- A **lab journal** records what you did, what happened, what you learned.
- Pros keep one so work is **repeatable** and **reportable**.
- It can be a notebook **or** a digital doc.

Your journal is your memory. Start it today, keep it all semester.

Your first journal entry

Baseline entry: write 3–5 sentences answering —

"What do I think hacking is right now?"

You'll revisit this at the end of the course to see how far you came.

Day 1 exit ticket

Finish the sentence in one line:

"Offensive security exists because ____."

Day 2 — Hats, teams, and the hacker mindset

The hacker "hats"

Hat	What they do	Legal?
White hat	Works with permission , reports problems	 Legal
Gray hat	Acts without permission , claims good intent	 Illegal
Black hat	Attacks for harm, theft, or gain	 Illegal

Gray hat is NOT a safe middle

- "I meant well" does **not** create authorization.
- A gray hat still accessed a system **without permission**.
- Good intentions don't change the law — or protect you.

If you don't have permission, the color of your "hat" doesn't matter.

Check your understanding

Which hacker acts **without** permission, usually claims good intentions, and is **still acting illegally**?

A) White hat B) Blue hat C) Gray hat D) Red hat

Answer

C — Gray hat.

- No permission = no authorization, no matter the intent.
- "I was only trying to help" is not a legal defense.

Gray is not a safe zone between white and black. It's just illegal.

Red team vs. blue team

Team	Role
Red team	The "attackers" — simulate real adversaries
Blue team	The "defenders" — detect, respond, stop attacks
Purple team	Red + blue working together to improve both

Both sides are on the **same side**: making the organization safer.

Check your understanding

In a security exercise, the **blue team** is the group that:

- A) Simulates attackers
- B) Writes the law
- C) Defends, detects, and responds
- D) Pays the bug bounties

Answer

C — Defends, detects, and responds.

- **Red** plays the attacker; **blue** plays the defender.
- **Purple** is the two teams sharing lessons to get better.

Red finds the holes; blue closes them.

The hacker mindset

- Deep **curiosity** about how things work.
- A drive to find clever, **unexpected** uses for things.
- Imagining how a system could be **misused** — then defending it.

This is a **defensive superpower** — when channeled ethically and with permission.

Same skill, different choice

Finding a hidden web page	Ethical	Illegal
Where?	Authorized lab / bounty target	A site you don't own
Permission?	Yes, in writing	None
Result?	A report that gets it fixed	A crime

The **skill** is identical. The **choice** is everything.

Day 2 exit ticket

"Why is 'gray hat' still risky and usually illegal?"

Journal prompt: describe a time your curiosity helped you figure something out — and how that same curiosity could be channeled in security.

Day 3 — The law: CFAA, scope & authorization

Rapid true/false warm-up

- "Scanning a site you don't own is fine if you change nothing." → **False**
- "Owning hacking tools is illegal." → **False**
- "Minors can't get in trouble for hacking." → **False**

The CFAA

The **Computer Fraud and Abuse Act** (18 U.S.C. § 1030) is the main U.S. federal anti-hacking law.

It prohibits:

- Accessing a computer "**without authorization**"
- "**Exceeding authorized access**" — allowed *here*, but you went *there*

State computer-crime laws stack on top of this.

"Exceeding authorized access"

- You were let into part of a system — but not all of it.
- Wandering past your permission is still a crime.
- Example: allowed to read your own grades, you peek at others'.

A key card to the lobby is not a key to every office.

Minors are NOT exempt

- Being a student does **not** make unauthorized access legal.
- Consequences: juvenile or criminal charges, school discipline, records.
- The goal isn't fear — it's **informed, ethical decisions.**

Check your understanding

True or False: Because they are minors, high-school students **cannot** get in legal trouble for unauthorized hacking.

Answer

False.

- Minors **are not exempt** from the CFAA or state law.
- Consequences can follow you for years.
- This is exactly why we build judgment first.

Age is not a shield. Authorization is the only thing that protects you.

"Just looking" can still be illegal

- Even **scanning** or "looking around" can break the CFAA and AUP.
- "I didn't change anything" is **not** a legal defense.
- The harm is the **unauthorized access itself**, not just damage.

Check your understanding

A friend says, "Scanning a website I don't own is fine as long as I don't change anything." Best response?

- A) Correct, looking is always legal
- B) Unauthorized scanning can still be illegal — "just looking" is no defense
- C) Only true on weekends
- D) Only true if you use Kali

Answer

B — Unauthorized scanning can still be illegal.

- The crime is **access without authorization**, not just damage.
- "I didn't break anything" won't save you.

Trespassing is illegal even if you don't take anything.

Tools are dual-use

- The **same tools** serve professionals and criminals.
- Owning a security tool is generally **legal**.
- **Using it without permission** is not.

A tool can't make an action legal or illegal — **authorization** does.

Check your understanding

"Tools are dual-use" means:

- A) Each tool does two things
- B) Same tools used by pros and criminals; owning them is generally legal, but unauthorized use is not
- C) You need two tools for every job
- D) Tools must be bought in pairs

Answer

B — Same tools, different users; use without permission is the crime.

- A wrench can build or break — the law judges the **action**.
- Authorization decides whether the use is legal.

The tool is neutral. The choice is not.

Authorization + scope = the line

Term	Meaning
Authorization	Explicit, written permission to test a system
Scope	The exact systems and actions you may test — nothing else

The same scan is a **job** with authorization, and a **crime** without it.

Reading a scope (worked example)

A scope document might say:

-   In scope: `app.example.com`
-   Out of scope: every other Example server
-   Outside scope = unauthorized = a crime

Staying in scope is not a suggestion — it's the law for that job.

Day 3 exit ticket

"In your own words: what is the difference between a pentester and a criminal?"

Then begin **Part 1 of the Scenario Worksheet** (legal vs. illegal, scenarios S1–S4).

Day 4 — Responsible disclosure, bug bounties & real cases

The grading-portal problem

A student finds the school grading portal shows **other students' grades** if you change a number in the web address.

What is the **right** thing to do?

What could go wrong if they "just look around to be sure"?

Why "just to confirm" is the trap

- Changing the number is **exceeding authorized access**.
- "Confirming it's real" is the exact step that becomes a crime.
- The safe move: stop the moment you suspect a problem.

The instant you act on it without permission, you crossed the line.

Responsible disclosure

If you discover a real vulnerability — even by accident:

-  Do **not** exploit it further.
-  Do **not** share it publicly or with friends.
-  **Report it privately** to the owner or a trusted adult.
-  Give them time to fix it.

Discover by accident → stop → report. Don't poke at it to "be sure."

Check your understanding

You **accidentally** find a real vulnerability in an app you use. Responsible disclosure means you:

- A) Exploit it to prove it's real, then post it
- B) Tell friends so they can try too
- C) Don't exploit or share it; report it privately
- D) Ignore it and never tell anyone

Answer

C — Don't exploit or share it; report it privately.

- Report to the owner or a trusted adult, and give time to fix.
- Exploiting or posting it turns an accident into a choice to do harm.

Found it by accident? Stop, then report. That's the whole rule.

Bug-bounty programs

- A **bug bounty pays** ethical hackers to find and report bugs — legally.
- The company publishes a **scope page** = your authorization.
- This is **coordinated disclosure**: the rewarded, legal path.

Want to use these skills for real? Bug bounties and CTFs are the legal door.

Check your understanding

A bug-bounty program is:

- A) A contest to write the most bugs
- B) A program where organizations **pay** ethical hackers to find and report bugs legally
- C) A type of malware
- D) A school club

Answer

B — Organizations pay ethical hackers to find and report bugs, legally.

- The published **scope page** is your written authorization.
- Stay in scope, report through the program, get paid.

It's the legal, rewarded version of the curiosity you already have.

Responsible-disclosure role-play

In pairs, practice a real report:

- **Discoverer** — found the issue by accident.
- **Owner** — the IT contact receiving the report.
- (**Observer** — gives feedback, if you have a third.)

Report it **clearly, respectfully, privately** — don't exploit or share. Then **swap roles**.

What a good report sounds like

- "I noticed something by accident and stopped right away."
- "Here's what I saw, with enough detail to reproduce it."
- "I haven't shared this with anyone — please take the time to fix it."

Calm, clear, private, and helpful. No bragging, no threats.

Day 4 exit ticket

*"Name one thing a responsible hacker does **not** do after finding a bug."*

Then finish the **Scenario Worksheet** (Part 2: ethical vs. unethical, S5-S8).

Day 5 — Learning to learn + the ethics pledge

Effective learning strategies

- **Take good notes** — your lab journal is your memory.
- **Break problems into steps**; document what you tried.
- **Ask for help the right way**: tried / happened / expected.
- Persistence beats raw talent in this field.

The "Try Harder" mindset

- **Persistence and productive struggle** before giving up.
- Sitting with a hard problem is where learning happens.
- It is **NOT** recklessness or rule-breaking.

Frustration is **never** an excuse to attack something out of scope.

Check your understanding

The "Try Harder" mindset means:

- A) Attack the system until it breaks, rules or not
- B) Persist and problem-solve through struggle — within the rules
- C) Skip the lab journal
- D) Always ask for the answer first

Answer

B — Persist through productive struggle, within the rules.

- "Try Harder" means **keep thinking**, not keep attacking.
- Stuck does not mean "go out of scope."

The rules are the box. Get creative *inside* it.

Strong vs. weak journal entries

Weak entry	Strong entry
"Did the lab. It worked."	Date, exact command, result, lesson
No reasoning	Notes <i>why</i> I tried something
Can't be repeated	Anyone could repeat my steps

Day 5: sign the pledge & assess

- Complete and **sign the ethics reflection** (pledge + reflection).
- Submit the completed **Scenario Worksheet** (all 8).
- Take the **Unit 01 quiz**.

Reflection prompt: *Why does authorization matter so much? Describe one time you might be tempted to cross a line, and what you'd do instead.*

Full vocabulary (1 of 3)

Term	Meaning
Offensive security	Attacking systems on purpose, with permission
Pentest / pentester	Authorized simulated attack / the pro who runs it
White hat	Ethical hacker; works with permission, reports issues
Gray hat	No permission, claims good intent — still illegal
Black hat	Criminal attacker, no permission

Full vocabulary (2 of 3)

Term	Meaning
Red / Blue team	Simulated attackers / defenders
Purple team	Red + blue working together
Hacker mindset	Curiosity + clever uses — a defensive superpower
Authorization	Explicit written permission to test a system
Scope	The exact systems/actions you may test — nothing else
CFAA	Main U.S. federal anti-hacking law (§ 1030)

Full vocabulary (3 of 3)

Term	Meaning
Vulnerability / Exploit	A weakness / the technique that abuses it
Responsible disclosure	Privately reporting a bug, not exploiting it
Bug bounty	Paid, legal program to find and report bugs
Scanning	Probing what's running — illegal without authorization
AUP	Acceptable Use Policy — the rules you agree to
Lab journal	Your running record of what you did and learned

Lab: Ethics, Law & the Hacker Mindset

No tools. No hacking. No scanning. You will read, classify, discuss, and role-play. There is nothing to attack here — and that is the point.



Lab safety & authorization reminder

You may run offensive techniques **only** inside approved, isolated labs — and only after your AUP is signed. Doing this to any system you don't own or have **written permission** to test — the school, classmates, or any website — is **illegal** under the CFAA and state law. **Minors are not exempt.**

Copy this onto **page 1** of your lab journal by hand.

Lab Part 1 — Journal setup

1. Get your lab journal (notebook or shared digital doc).
2. **Cover:** your name, course, term.
3. **Page 1:** copy the safety/authorization reminder.
4. Title it "Unit 01 — Ethics & Law" and date it.
5. Write your **baseline entry**.

 Photograph page 1 for your deliverable.

Lab Part 2 — Scenario classification

For each scenario, decide **two** things and justify each in one sentence:

- 1. Legal or illegal?** (Authorization? In scope?)
- 2. Ethical or unethical?** (Even if legal, was it right?)

Legal and ethical aren't always the same — say so in your reasoning.

Sample scenarios (1 of 2)

- **S1.** Maya signs a contract listing exact servers, tests only those, reports. → *Legal / Ethical*
- **S2.** Devon changes a grading-portal URL number "just to confirm," tells no one. → *Illegal / Unethical*
- **S4.** Sam port-scans a popular site "to practice," no permission, changes nothing. → *Illegal / Unethical*

Sample scenarios (2 of 2)

- **S6.** Alex scans a neighbor's Wi-Fi login "to check it's secure," plans to warn them. → *Illegal / Unethical*
- **S7.** Jordan completes a TryHackMe room on the class AttackBox. → *Legal / Ethical*
- **S8.** Riley logs into a classmate's email "as a joke," reads nothing. → *Illegal / Unethical*

Lab Part 3 — Disclosure role-play

In pairs, using a scenario card:

- 1. Assign roles** — Discoverer and Owner (Observer if 3).
- 2. Run the report** (5–7 min): private, clear, respectful — don't exploit.
- 3. Swap roles** and run it again.
- 4. Journal it:** what did a good disclosure sound like?

Lab deliverables

-   **Scenario Worksheet** (all 8, both classifications + justifications).
-   **Signed ethics reflection** (pledge + reflection).
-   **Lab journal**: page-1 reminder, baseline entry, role-play reflection + photo.

Recap (1 of 2)

- Offensive security exists because **you can't protect what you don't understand.**
- **White / gray / black hats** — gray is still illegal.
- **Red** attacks, **blue** defends, **purple** unites them.
- The **CFAA** bans access "without authorization" — **minors included.**

Recap (2 of 2)

- **Authorization + scope** is the line. **Tools are dual-use.**
- "Just looking" / scanning is **not** a safe defense.
- Found a bug? **Don't exploit, don't share — report privately.**
- Bug bounties are the legal path. **"Try Harder"** = persistence within the rules.

Exit ticket & discussion

1. What is the **single dividing line** between a pentester and a criminal?
2. Why is "just looking" or scanning **not** a safe defense?
3. You find a real bug by accident — what three things do you do (and not do)?

Discuss: The same scan is a paid job for one person and a crime for another. **Why?**

Submit: signed ethics reflection + Scenario Worksheet + lab journal page 1.